SOC Incident Investigation Report

Analyst Name: Loveth Adebayo
Date: October 22, 2026
Incident ID: SOC-2026-1022
Severity: High

1. Executive Summary

On October 22, 2026, at approximately 08:52 AM, a medium-severity alert was escalated to the Level 2 SOC team. The Windows endpoint (DESKTOP-ADDFGV1) experienced multiple failed logon attempts followed by a successful logon. Subsequent proactive threat hunting revealed that immediately following the successful logon, a PowerShell command was executed attempting to download a malicious payload from an external domain. The activity was confirmed malicious. The compromised IP was identified, and an automated Active Response (firewall-drop) was successfully configured and executed to contain the threat.

2. Incident Timeline

08:52 AM: Multiple failed logon attempts detected (Windows Event ID 4625 / Wazuh Rule 60122).
08:56 AM: Successful logon detected (Windows Event ID 4624 / Wazuh Rule 60106).
17:39 PM: Suspicious PowerShell command executed attempting to contact malicious-domain.com (Wazuh Rule 61109).
17:40 PM: File creation detected in the monitored directory: C:\Users\loveth adebayo\SensitiveFiles\payload.exe (Wazuh Rule 554).
18:27 PM: Active Response triggered, blocking the attacker IP (10.79.147.219) for 600 seconds.

3. Indicators of Compromise (IOCs)

Malicious Domain: http://malicious-domain.com/payload.exe

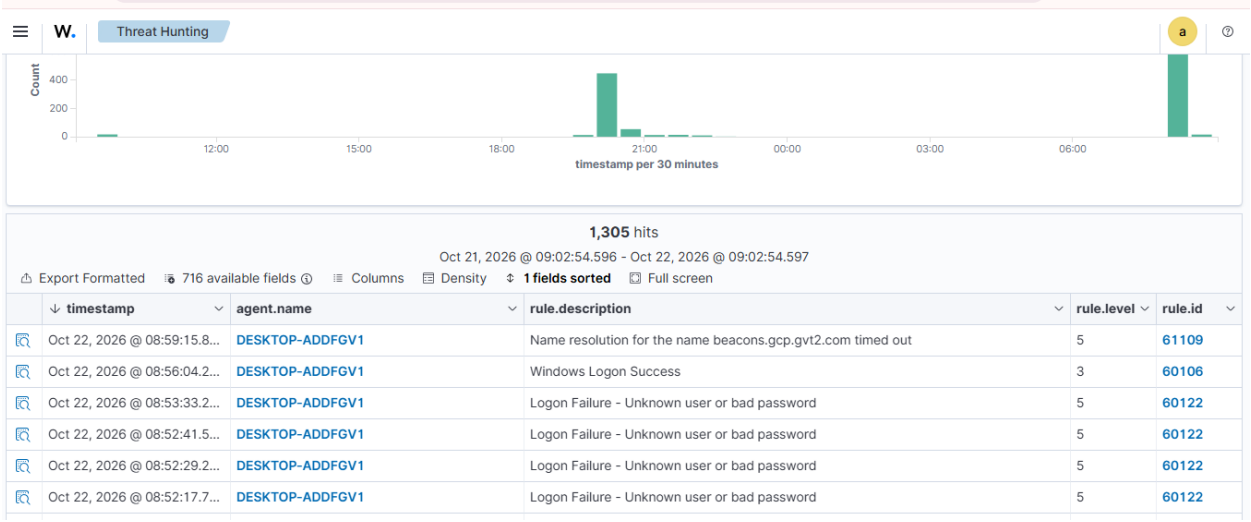
File Artifact: payload.exe (Attempted download to SensitiveFiles directory)

Source IP: 10.79.147.219 (Attacker IP blocked by Active Response)

Event IDs: 4625 (Failed Logon), 4624 (Successful Logon), 4104 (PowerShell Script Block), 4688 (Process Creation).

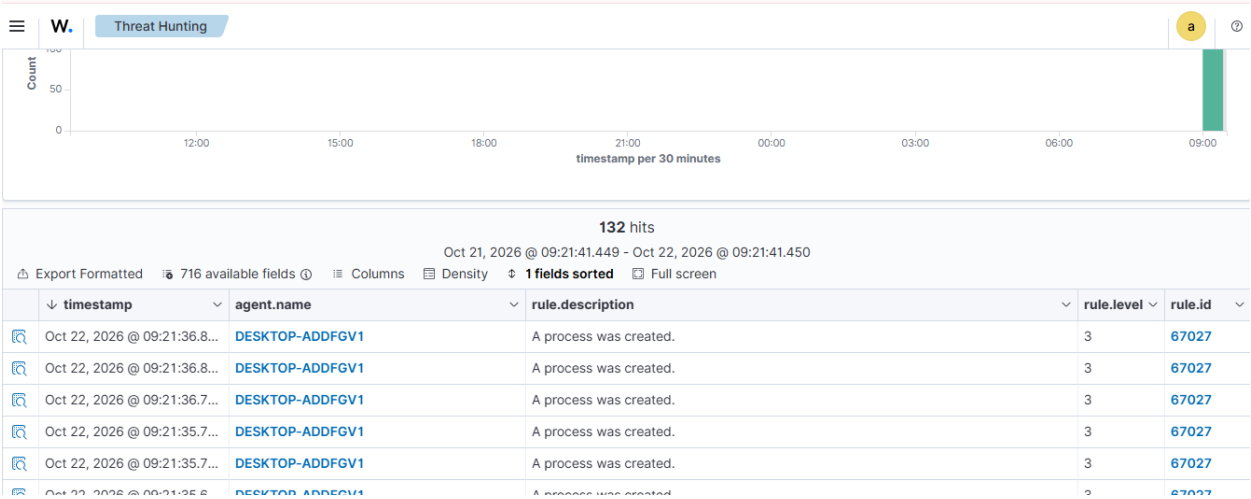
4. Investigation Findings and Evidence

Authentication Analysis: Wazuh successfully identified a brute-force pattern.



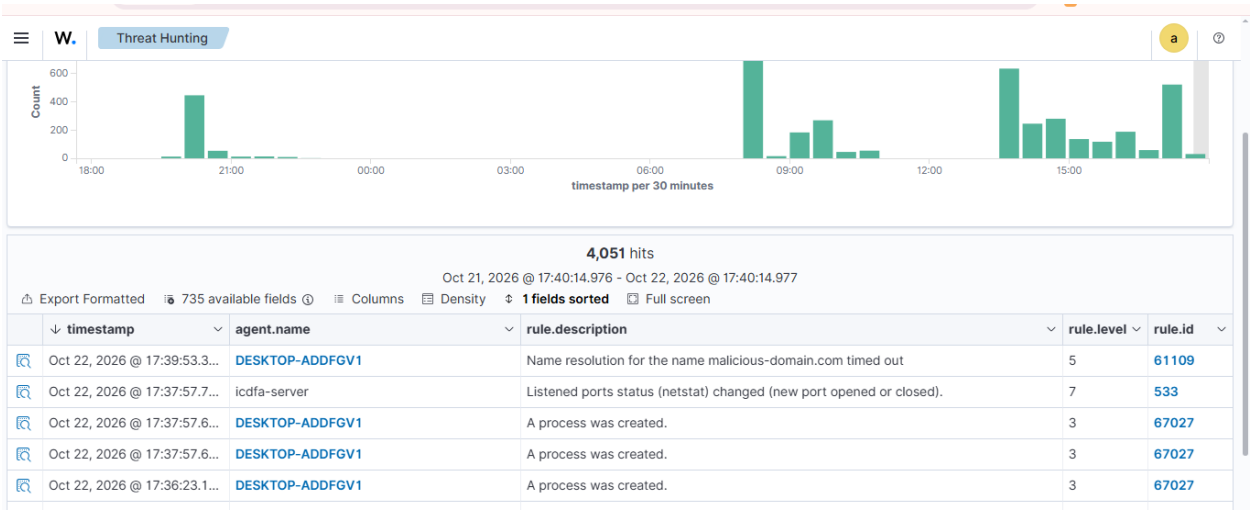
Phase1_Logon_Events

Process Execution: Audit policies were enabled, allowing Wazuh to capture process creation events.



Phase1_Process_Execution

PowerShell Analysis: The endpoint attempted to reach a known malicious domain.



Phase2_PowerShell_4104

Containment: The Wazuh Active Response module was configured with a firewall-drop command (Rule 5710) for a 600-second timeout.

```
  GNU nano 4.8                          /var/ossec/etc/ossec.conf
</ossec_config>

<ossec_config>
  <localfile>
    <log_format>journald</log_format>
    <location>journald</location>
  </localfile>

  <localfile>
    <log_format>syslog</log_format>
    <location>/var/ossec/logs/active-responses.log</location>
  </localfile>

  <localfile>
    <log_format>syslog</log_format>
    <location>/var/log/dpkg.log</location>
  </localfile>

<command>
  <name>firewall-drop</name>
  <executable>firewall-drop</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>

<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>5710,60122</rules_id>
  <timeout>600</timeout>
</active-response>

</ossec_config>



icdfa-server@icdfa-server:~$
```

Phase3_ActiveResponse_Config

The log confirms the IP was blocked.



ActiveResponse_Log

5. Advanced Analysis Questions

Question 1: Why is the sequence of "failed logons -> successful logon -> immediate PowerShell execution" so highly suspicious?

Answer: This sequence is a classic indicator of a credential-based attack (brute force or password spraying). The attacker fails repeatedly, eventually guesses the password, logs in, and immediately uses PowerShell to download malware or establish persistence. Legitimate users do not typically fail multiple times and then instantly run obfuscated PowerShell commands.

Question 2: How did proactive threat hunting provide a more complete picture?

Answer: The initial alert only showed the logon anomaly. Proactive hunting allowed the analyst to correlate the logon event with subsequent process creation (4688) and PowerShell script blocks (4104). This connected the dots, proving the login was not just a user working late, but an active compromise leading to a malicious payload download.

Question 3: What is a potential risk of automatically blocking an IP address for 10 minutes?

Answer: The primary risk is a "False Positive" Denial of Service (DoS). If a legitimate user accidentally triggers the rule with typos, blocking their IP will lock them out of critical systems. Additionally, sophisticated attackers often use rotating IPs, meaning the block might be ineffective against the real attacker.

Question 4: If the attacker's IP is blocked, what is one other technique they might use to regain access, and how could Wazuh detect it?

Answer: The attacker might pivot to a different endpoint or use a different IP address (e.g., via a VPN or proxy) to launch a new attack. Wazuh can detect this by utilizing its centralized logging; if an attacker attempts lateral movement to another agent, Wazuh will correlate the alert across the network and trigger Active Response on the new endpoint.

6. Recommendations

1. Enforce MFA: Implement Multi-Factor Authentication to prevent credential compromise even if passwords are guessed.

2. Network Segmentation: Isolate critical endpoints to prevent lateral movement.

3. User Training: Educate users on recognizing phishing attempts and the importance of strong passwords.